┌──(hackbot㉿ifpb)-[~/IFTech]

Welcome back,
Aluno(a)!

Hackbot 1.8 (1M contex)
IFPB's Individual Org

Tips for getting started

Run /init to create a CLAUDE.md file with instructions for Hackbot

Note: You have launched claude in your home directory. For the best experience,launch it

What's new

You can hack now (ethically, obviously)

INSTITUTO FEDERAL
Paraíba

> "Hackbot, hackeie a nasa... use força total do Megabrain e não cometa erros"

Sumário>

- Parte 1:
  - LLMs, IA generativa, Agentes autônomos
  - Como criar um bom contexto?
  - Tokens (e porque se fala tanto nisso?)
- Parte 2:
  - Web
  - HTTP & DNS & URL
  - Aplicações Web modernas... muito contexto...
  - Webhacking + CTF
  - Vulnerabilidades: IDOR & Command Injection
  - Prática: IDOR (PortSwigger) & Command Injection (Lab docker)
- Parte 3:
  - Agents? Hackbot? & Design do Hackbot
  - MCP & Harness
  - Skills + Profundidade Humana & Amplititude da IA
  - Criando o hackbot + Prompts + Hackbot em prática

O que você deve esperar desse minicurso?

- Entender o que são LLMs, agentes?
- Entender um pouco mais sobre web e webhacking
- Conhecer o claude-cli e Deepseek-pro
- Como criar seu próprio Hackbot inicial
- Testar seu hackbot com o Portswigger Academy

e... 😈



“Muito falso positivo... melhore a abordagem”

Quem somos nós?



Rodrigo Padilha

Pentester, CTF Player & Bug Bounty Hunter

Tecnólogo em Redes (IFPB)

SCAN ME



Júlio Caio

OSINT enthusiast

Tecnólogo em Redes (IFPB)

SCAN ME

Capítulo 1: IA

O que é Machine Learning, LLMs e IA generativa?

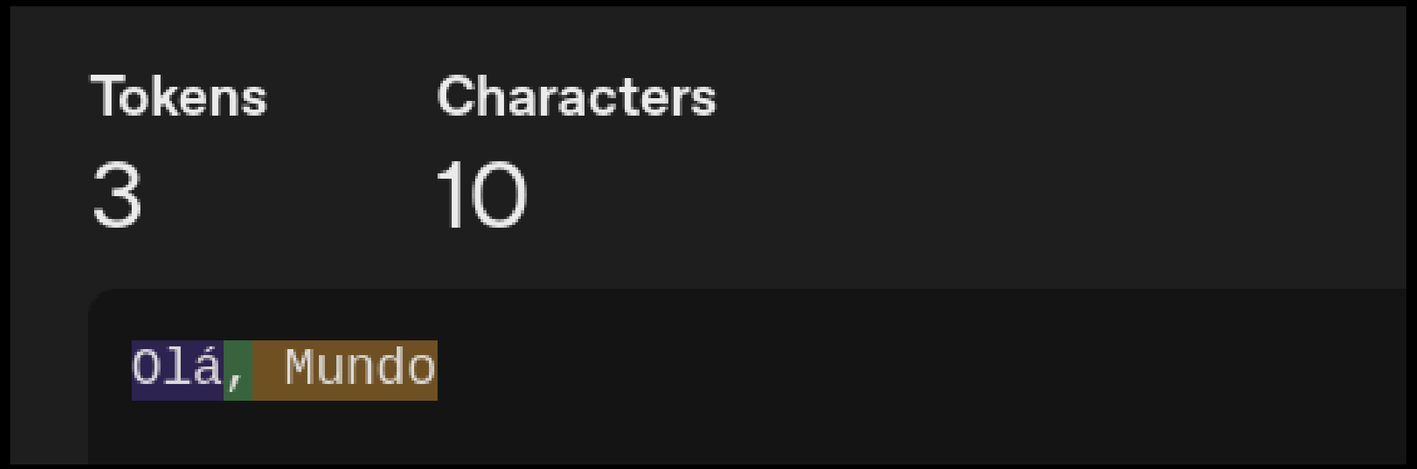
Machine Learning: É um subcampo da área da Inteligência Artificial. Concentra-se em algoritmos que podem "aprender" os padrões de dados de treinamento e, posteriormente, fazer inferências precisas sobre novos dados.

LLM: são uma categoria de modelos de deep learning treinados em imensas quantidades de dados (bilhões, trilhões de parâmetros), tornando-os capazes de entender e gerar linguagem natural e outros tipos de conteúdos.

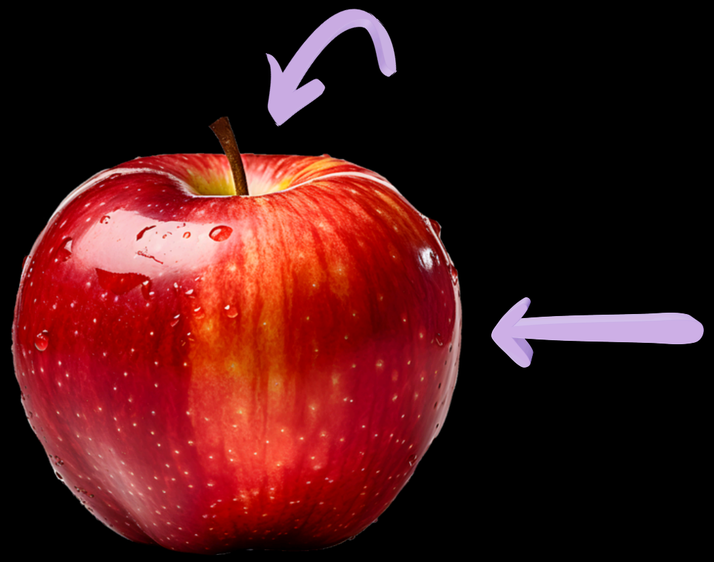
IA generativa: são modelos de deep learning, que funcionam identificando e codificando os padrões a fim de usar essas informações para entender as solicitações ou perguntas de linguagem natural dos usuários e responder com novo conteúdo relevante.

O que são tokens?

Os modelos de linguagem de grande porte processam texto usando tokens, que são sequências comuns de caracteres encontradas em um conjunto de texto. Os modelos aprendem a compreender as relações estatísticas entre esses tokens.



Como um modelo aprende? Exemplo Prático



Pré-definições

- Formato esférico
- Cor vermelha com tons laranja
- Caule no canto superior

Como um modelo aprende? (resuminho)

Passamos um conjunto de amostras, e com base num conjunto de testes de inferência de padrões, o modelo vai alimentando sua base de dados.

AMOSTRAS









Desafio: *“É uma maçã?”*



Como um modelo aprende? (resuminho)

"É uma maçã?"



Isso NÃO é uma maçã



- É esférica? **Não** (-1)
- Possui uma fenda superior? **Sim** (+1)
- Possui caule? **Sim** (+1)
- Possui tons amarelados? **Não** (-1)
- Possui tons vermelhos? **Não** (-1)

Capítulo 2: WEB HACKING

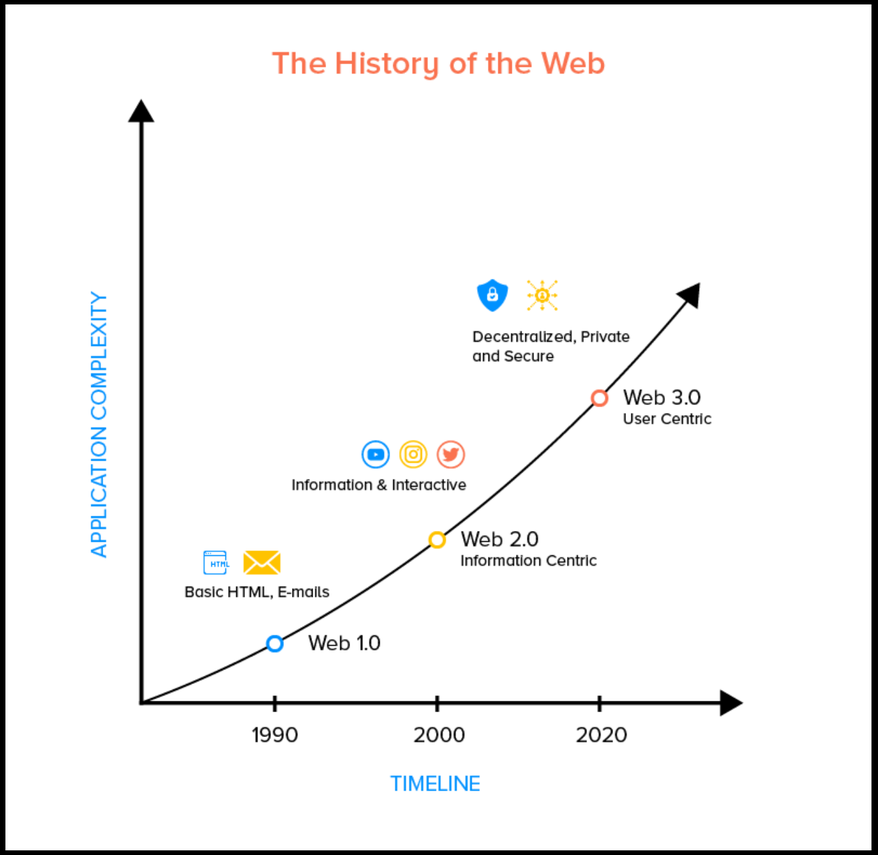
WEB ???

World Wide Web: É um sistema de documentos e recursos interligados por hiperlinks, acessíveis por meio da Internet utilizando navegadores como Chrome, Firefox e Safari.

Web 1.0: Web estática, onde o usuário principalmente consumia informações.

Web 2.0: Web interativa, onde o usuário consome, cria e compartilha conteúdo.

Web 3.0: Web baseada em descentralização, blockchain e propriedade digital, buscando reduzir a dependência de intermediários.

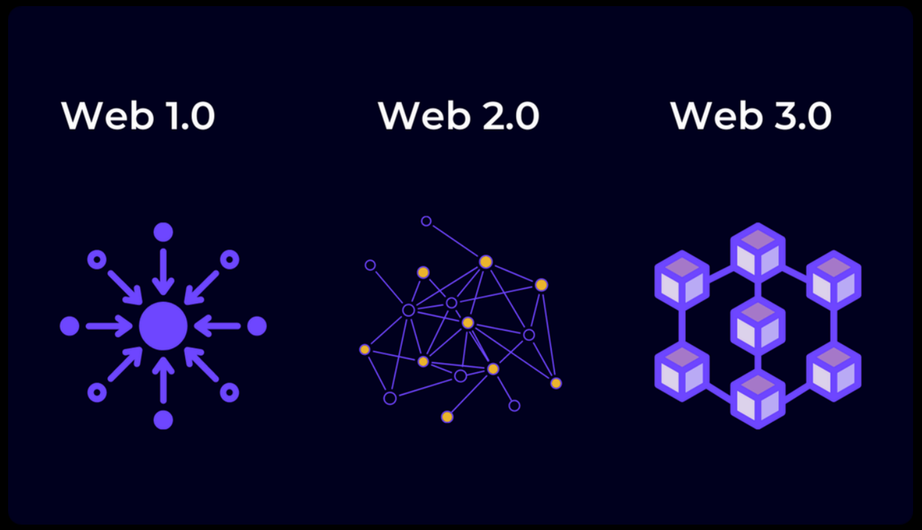


WEB ???

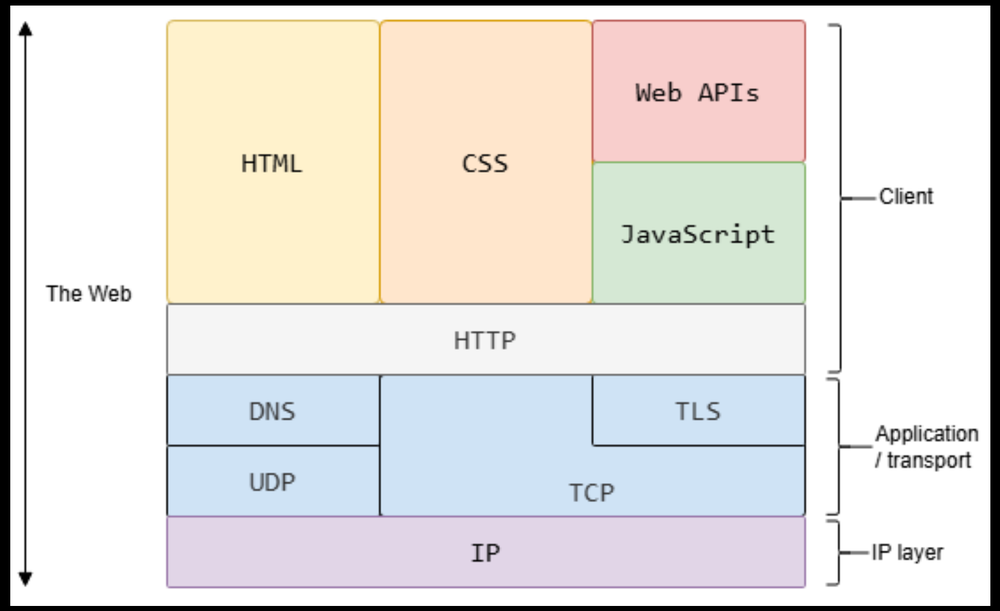
Web 1.0: https://www.webdesignmuseum.org/

Web 2.0: https://www.youtube.com/

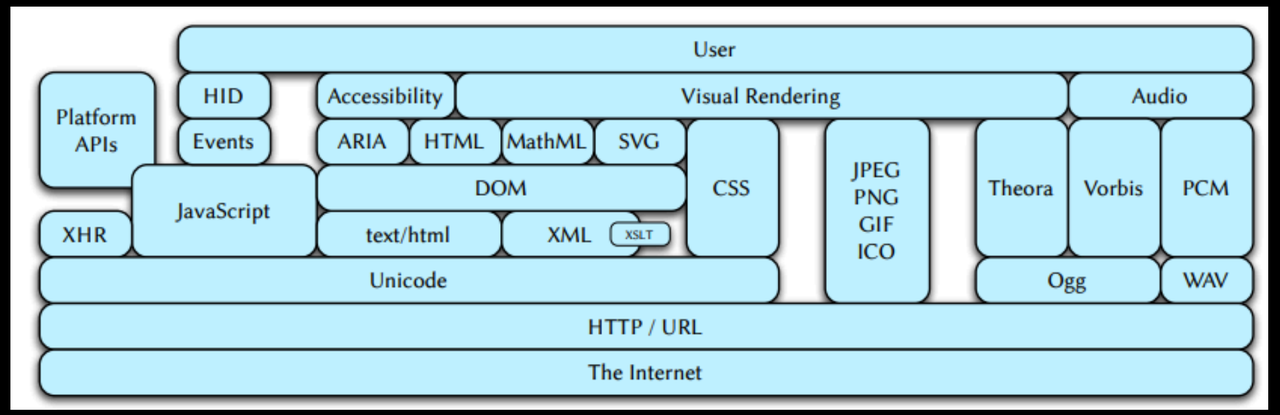
Web 3.0: https://ethereum.org/



WEB ???



https://developer.mozilla.org/pt-BR/docs/Web/HTTP/Guides/Overview

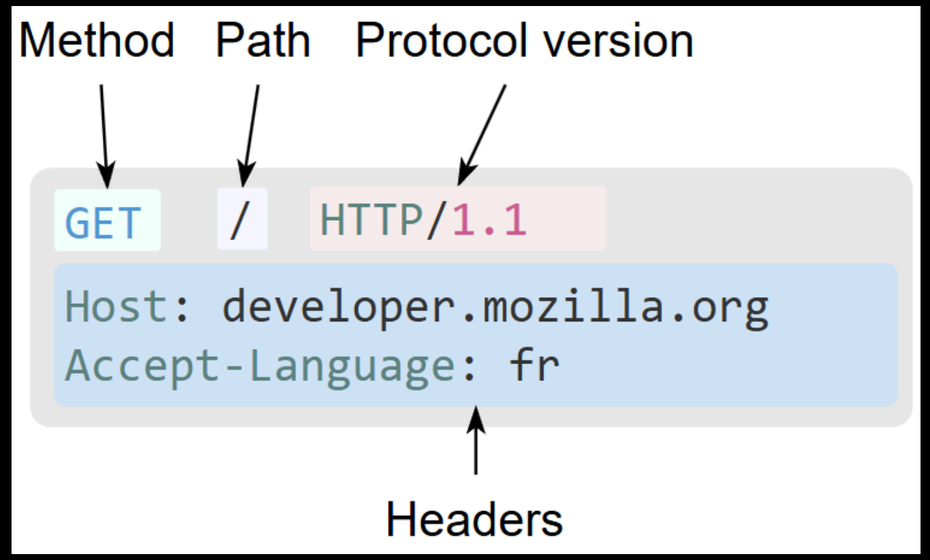


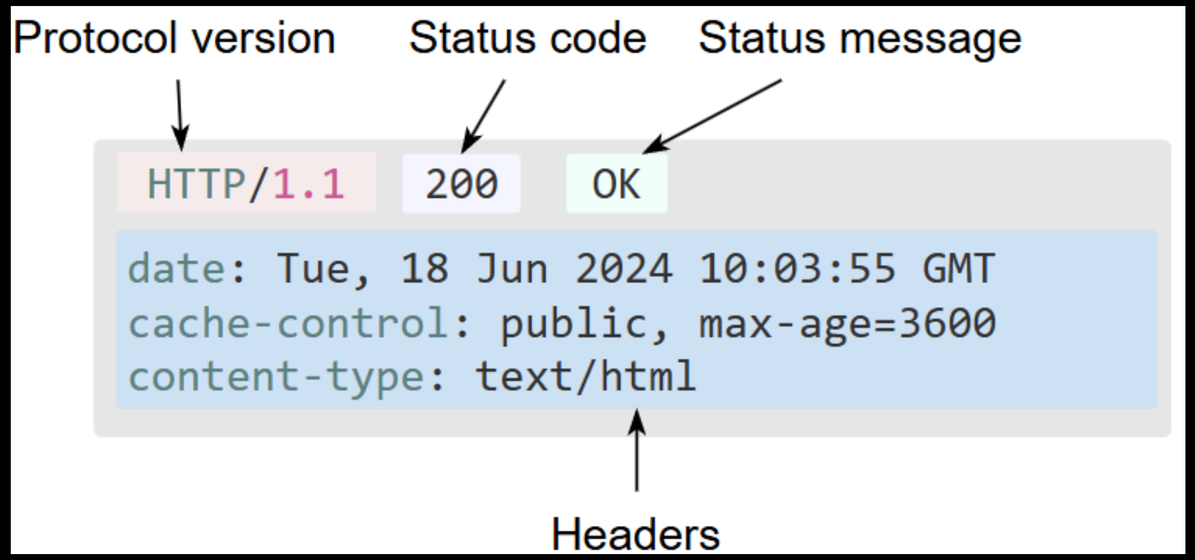
https://hsivonen.fi/web-stack/technology-stack-v2.pdf

Protocolo Hypertext Transfer Protocol (HTTP)

HTTP: Protocolo da camada de aplicação responsável desenvolvido para transferir informações entre dispositivos em rede e é executado no topo de outras camadas da pilha de protocolos de rede. É um protocolo stateless.

- HTTP: Os dados viajam em texto puro. Outras pessoas podem ler o que você envia se interceptarem a rede.
- HTTPS: A versão segura. Os dados são criptografados para proteger senhas e informações pessoais.





https://developer.mozilla.org/pt-BR/docs/Web/HTTP/Guides/Overview

Protocolo Hypertext Transfer Protocol (HTTP)

Method	Safe	Idempotent	Cacheable
`GET`	Yes	Yes	Yes
`HEAD`	Yes	Yes	Yes
`OPTIONS`	Yes	Yes	No
`TRACE`	Yes	Yes	No
`PUT`	No	Yes	No
`DELETE`	No	Yes	No
`POST`	No	No	Conditional*
`PATCH`	No	No	Conditional*
`CONNECT`	No	No	No

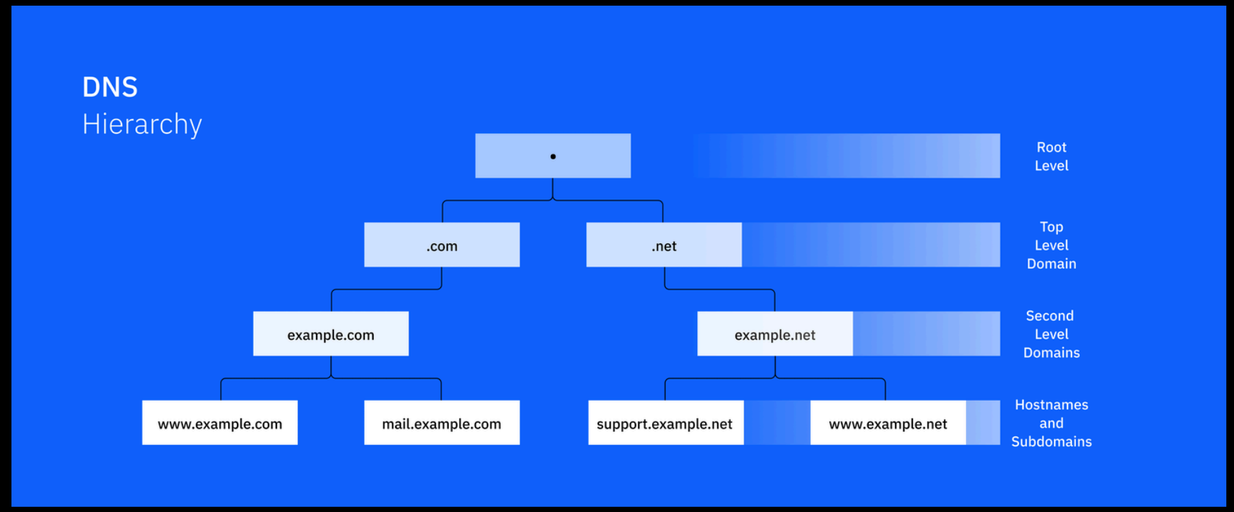
1. Informational responses (`100` – `199`)
2. Successful responses (`200` – `299`)
3. Redirection messages (`300` – `399`)
4. Client error responses (`400` – `499`)
5. Server error responses (`500` – `599`)

Domain Name System (DNS)

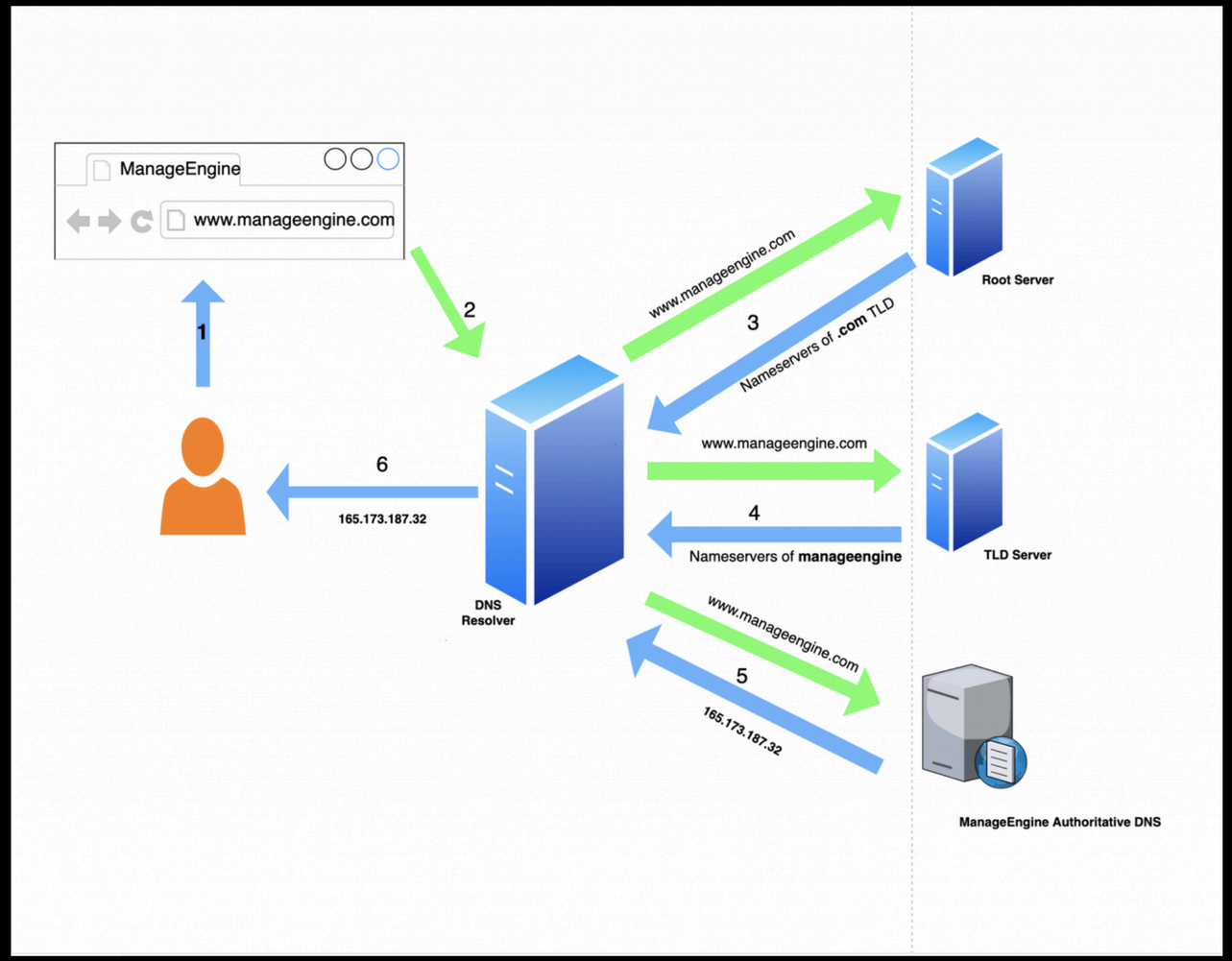
DNS: Protocolo da camada de aplicação, é basicamente a lista telefônica da internet. Ele converte nomes de sites fáceis de lembrar (como google.com) em endereços IP numéricos (como 142.250.190.46) que os computadores usam para se conectar.

```
root@pad1ryoshi:~# dig A ifpb.edu.br +short
200.129.77.39
root@pad1ryoshi:~#
```

```
root@pad1ryoshi:~# dig A hackerone.com +short
104.18.36.214
172.64.151.42
root@pad1ryoshi:~#
```



Domain Name System (DNS)



https://www.manageengine.com/br/blog/general/como-funciona-o-dns.html

Domain Name System (DNS)

```
; zone file for example.com

$TTL    86400             ; default TTL for this zone (1 day)
$ORIGIN example.com.  ; base domain-name

; Start of Authority record defining the key characteristics of this zone
@       IN      SOA     ns1.example.com. hostmaster.example.com. (
                        2019011501         ; Serial number. Increase it when this file is changed.
                          604800         ; Refresh
                           86400         ; Retry
                         2419200         ; Expire
                           86400 )       ; Negative Cache TTL

; Name servers for this domain
        IN      NS      ns1.example.com.
        IN      NS      ns2.example.com.

; Mail servers for this domain. A small number (10) indicates this server has higher priority.
        IN      MX  10  mail.example.com.
        IN      MX  20  mx2.linuxbabe.com.

; A records
www     IN      A       12.34.56.78
@       IN      A       12.34.56.78
ns1     IN      A       12.34.56.79
ns2     IN      A       12.34.56.78
mail    IN      A       12.34.56.78

; AAAA records
mail    IN      AAAA    2600:3c01::f03c:23ff:fe74:fe14

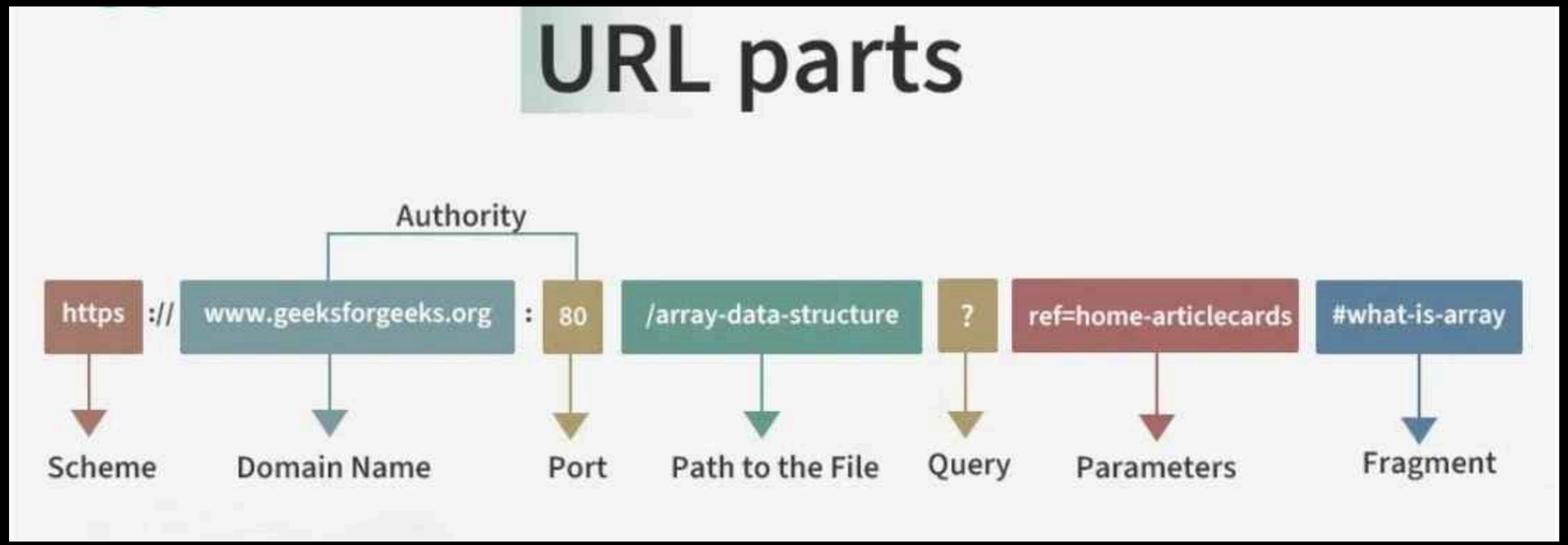
; CNAME records
ftp     IN      CNAME   www.example.com.

; TXT records (SPF, DKIM, DMARC, etc)
@                   IN      TXT     "v=spf1 mx ~all"
dkim._domainkey IN      TXT      ("v=DKIM1; p="
  "MIIBIjANBgkqhkiG9w0BAQEFAAOCAQ8AMIIBCgKCAQEA1Qtps4jFWauWVpDPHc28"
  "tccXh0+aHFtxkU4IBRE82wNwzkQ5yETbmYFqyWjY9XCMxv69CDmv1XOLpQVjdpxV"
  "wgk2FejY386g4apGE3wG47m5usEzfxdacEjsmc/wCfTWxOL8gJA3E8U5KrFun49R"
  "Q4rubODFUAGyOC+2s7fq1VlGL0pDk74vN9p7WtOWj/KYyPA6+SuGudClUXI5/KgK"
  "KuG/wL9u37VGu2mYsLLYAtZH8sijP9iWAMNC7ixrjnAXA8e9W4CCvwQYYp87gjnb"
  "Bv2IWWlGSJewYrrRsQMS5DwG/U25O0g9jKDxA0Ff7rKaRiuVJQd5DChNBLE12g7c"
  "oQIDAQAB")
_dmarc          IN      TXT     "v=DMARC1; p=none; pct=100; rua=mailto:dmarc-reports@example.com"
```

https://www.linuxbabe.com/ubuntu/set-up-authoritative-dns-server-ubuntu-18-04-bind9

Uniform Resource Locator (URL)

URL: Uma URL é um endereço web exclusivo usado para identificar e acessar recursos disponíveis na internet. Ela permite que os usuários localizem páginas, arquivos e serviços online por meio de um navegador.



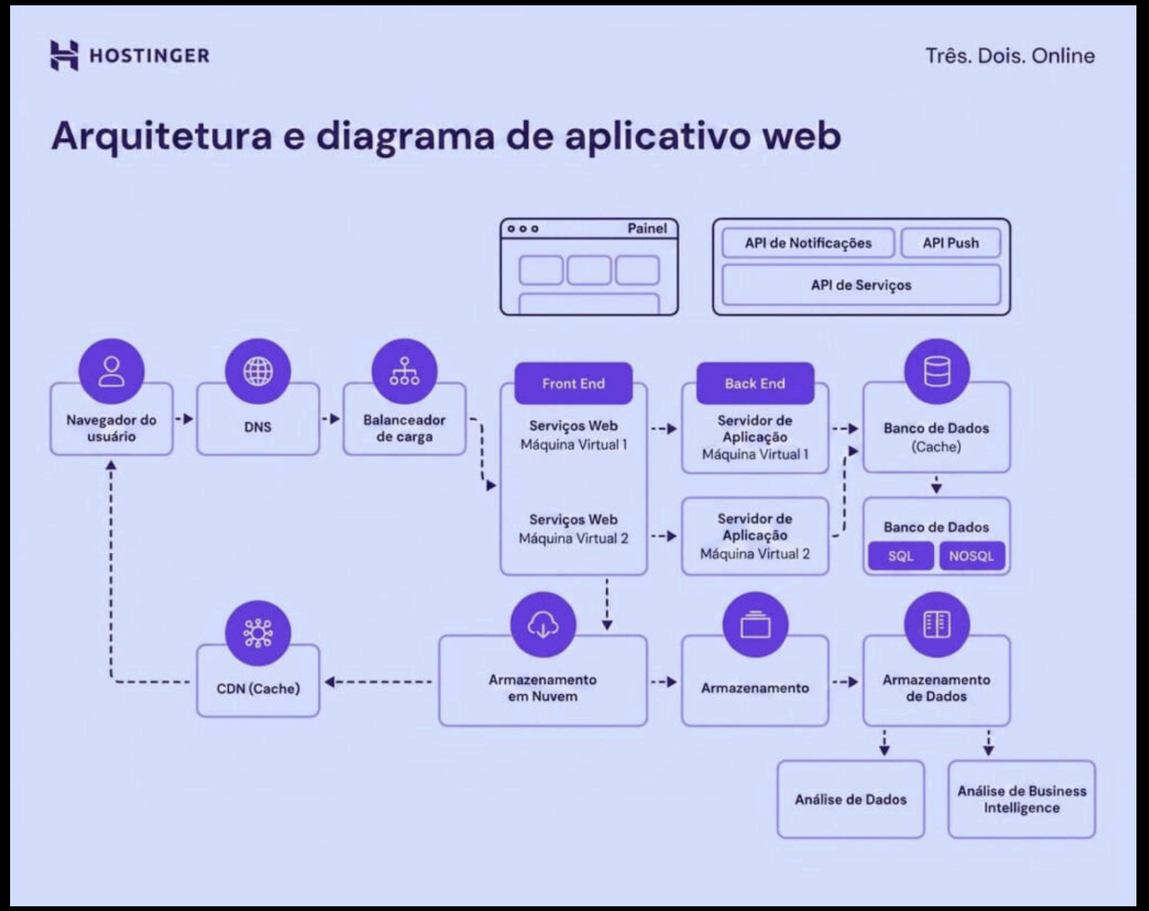
https://www.geeksforgeeks.org/javascript/what-is-url-uniform-resource-locator/

Aplicações Web Modernas

A aplicação web moderna:

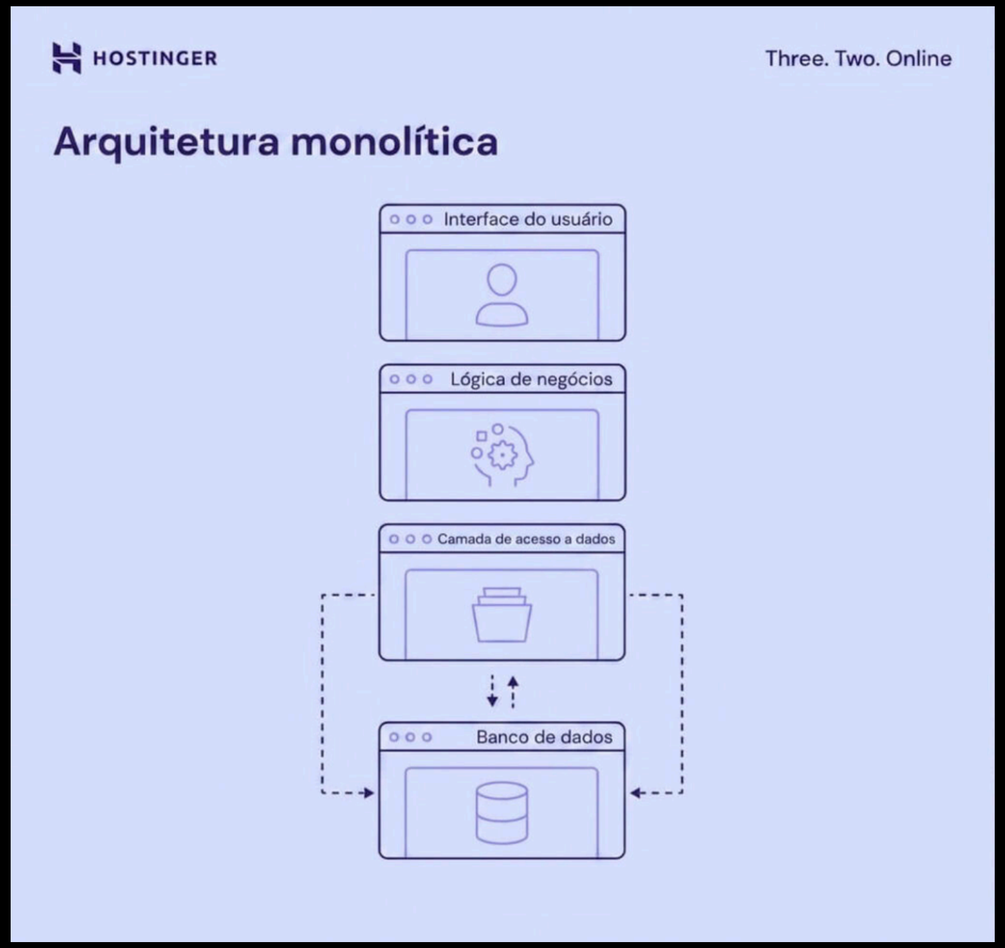
- Lado do cliente (front-end)
- Lado do servidor (back-end)
- Banco de dados
- Servidor web
- Servidor de aplicativos
- Camada de API
- Balanceador de carga
- CDN (Rede de Distribuição de Conteúdo)
- Componentes de segurança
- Monitoramento e registro

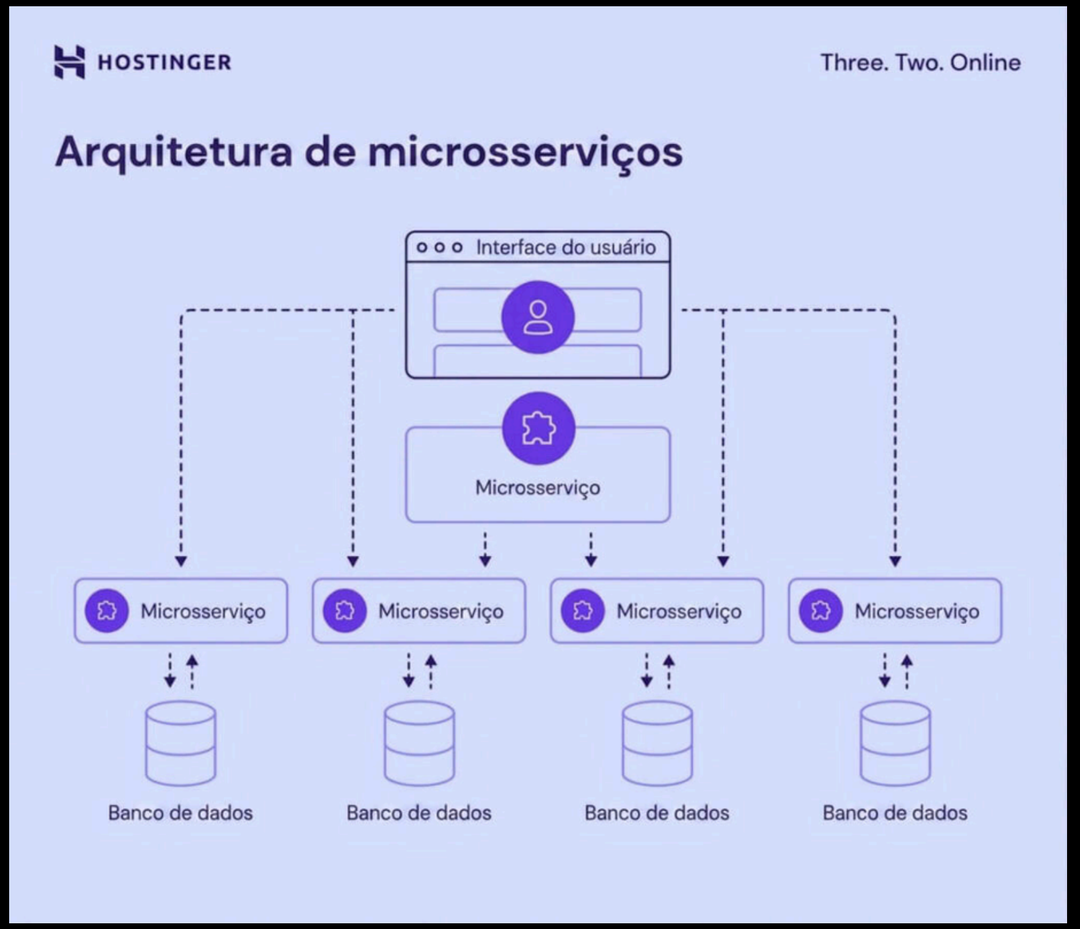
OBS: “Moderno” = tecnologias que a maioria das pessoas usam



https://www.hostinger.com/br/tutoriais/arquitetura-aplicacoes-web/

Aplicações Web Modernas - Exemplos de Arquiteturas





Como aprender a hackear essas aplicações web gigantescas?

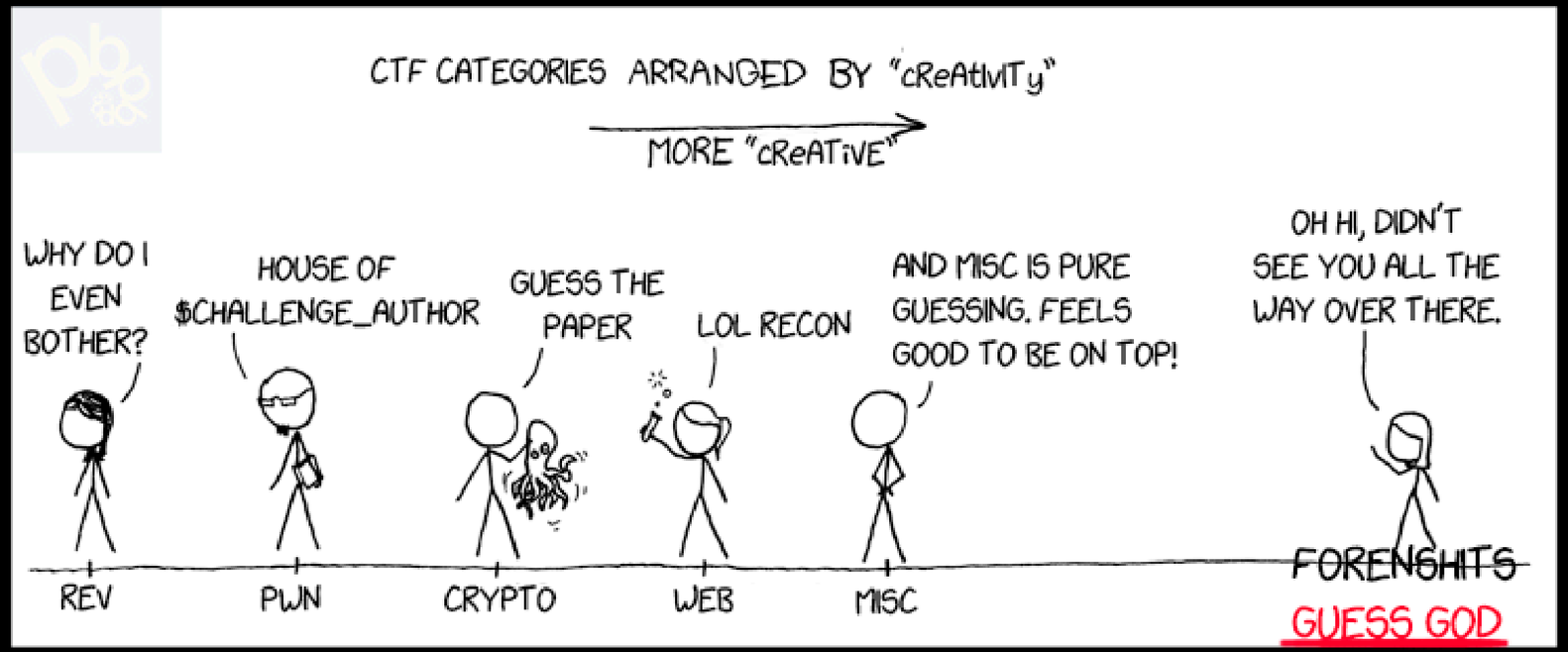
Cursos =
Faculdades =
Certificações =



CAPTURE THE FLAG =

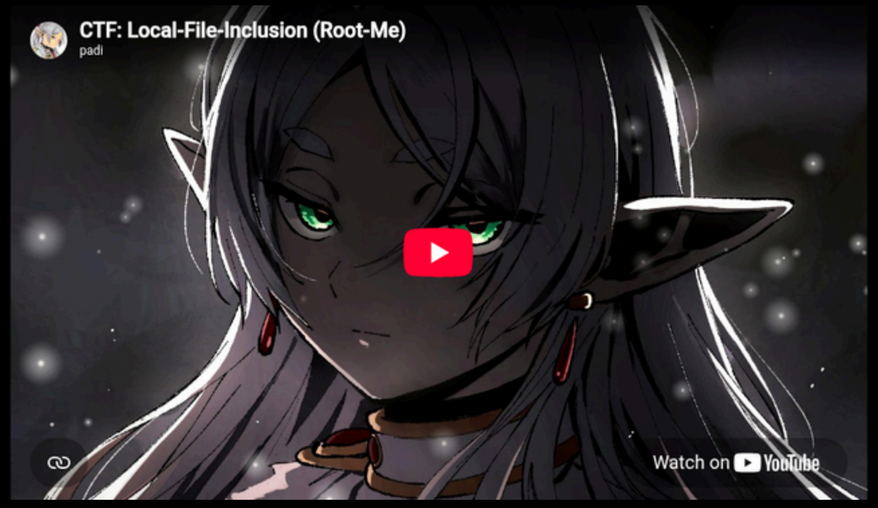


Quer aprender web(hacking)?











Material + Sites para aprender mais sobre CTF & Webhacking

Root-me: https://www.root-me.org/?lang=en

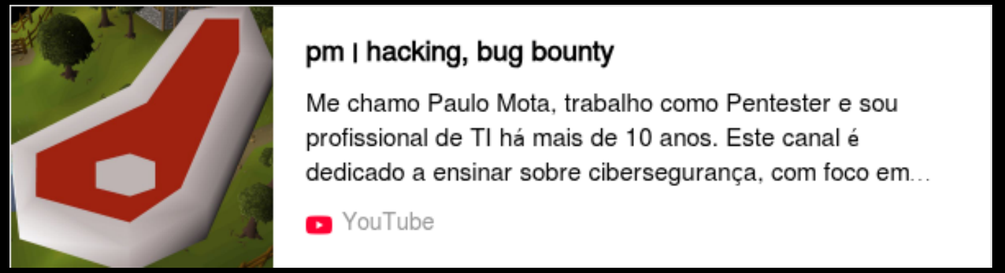
HackTheBox: https://www.hackthebox.com

TryHackMe: https://tryhackme.com

PortSwigger Academy: https://portswigger.net/web-security

Caon AppSec & Bug Bounty Hunter: https://caon.io





Vulnerabilidades: IDOR & Command Injection

Insecure Direct Object References (IDOR): Vulnerabilidade que ocorre quando uma aplicação permite que usuários acessem ou modifiquem diretamente objetos (como arquivos, registros de banco de dados ou URLs) com base em entradas fornecidas pelo usuário, sem controles de acesso adequados. Isso significa que, se um usuário alterar o valor de um parâmetro (como um ID) em uma URL ou requisição de API, ele poderá conseguir acessar ou manipular dados que não está autorizado a visualizar ou modificar de outros usuários.

Command Injection: Vulnerabilidade que permite a um atacante executar comandos do sistema operacional dentro da aplicação vulnerável.

Vulnerabilidades: IDOR

```
GET /api/users/1234/profile HTTP/2
Host: example.com
Authorization: Bearer eyJ...
User-Agent: ...
```

```
HTTP/2 200 OK
Server: Nginx
Content-Type: application/json
Content-Length: 23

// Data of user ID 1234
```

```
GET /api/users/1235/profile HTTP/2
Host: example.com
Authorization: Bearer eyJ...
User-Agent: ...
```

```
HTTP/2 200 OK
Server: Nginx
Content-Type: application/json
Content-Length: 23

// Data of user ID 1235
```

```php
<?php
    $user_id = $_GET['user_id'];
    $user_info = get_user_info($user_id);
    ...
```



Reddit disclosed on HackerOne: Deleting all DMs on RedditGifts.com

Summary: It's possible to delete all 4.4M private messages on RedditGifts.com due to missing permission...

HackerOne



Lab: Insecure direct object references | Web Security Academy

This lab stores user chat logs directly on the server's file system, and retrieves them using static URLs. Solve the lab by finding the password for the ...

WebSecAcademy



Vulnerabilidades: Command Injection

pad1ryoshi/
hackbot-iftech



Repositório com o material utilizado para a apresentação "Construindo um Hackbot com IA para Testes de Segurança em Aplicações Web"...

1 Contributor 0 Issues 5 Stars 2 Forks

hackbot-iftech/command-injection/cowsay at main • pad1ryoshi/hackbot-iftech

Repositório com o material utilizado para a apresentação "Construindo um Hackbot com IA para Testes de Segurança em Aplicações Web" no IFTech 2026. - pad1ryoshi/hackbot-iftech

GitHub

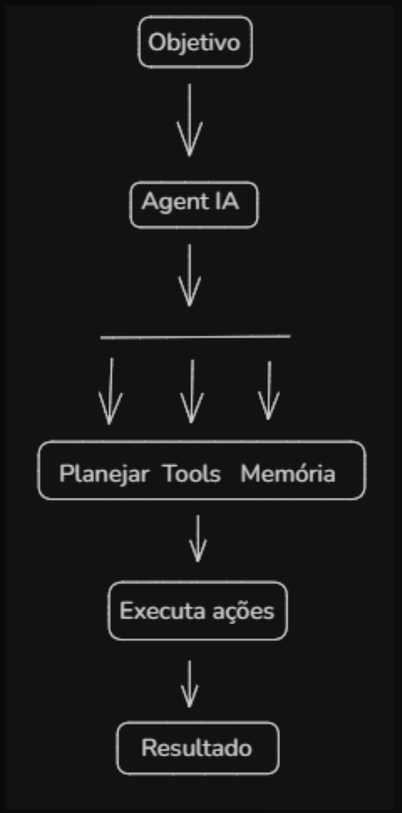
Capítulo 3: Criando + Hackbot em ação

Agents + Hackbot

Um Agent AI é uma IA que recebe um objetivo, pensa nos passos necessários, usa ferramentas e executa ações até completar a tarefa.

Um Hackbot é um conjunto de agentes que trabalham entre si para realizar determinado objetivo.

- Recon?
- Testar determinado parâmetro?
- Testar algum fluxo específico da aplicação?



Agents + Hackbot

```
padi@pad1ryoshi:~/dupe/Hackbot$ ls
CLAUDE.md       README.md  cross-engagement  hooks   references
COORDINATOR.md  agents     engagements       intake  reports
padi@pad1ryoshi:~/dupe/Hackbot$ ls agents/
api-testing      cors             graphql          path-traversal       ssti
auth             crlf             idor             postmessage          subdomain-takeover
business-logic   cspt             info-disclosure  privilege-escalation  websocket
cache-poisoning  csrf             local-privesc    prototype-pollution   xs-leaks
chaos            deserialization  mass-assignment  race-condition        xss
clickjacking     esi-injection    nosqli           request-smuggling     xxe
cmdi             file-upload      open-redirect    sqli
code-review      forge            parsing-bugs     ssrf
padi@pad1ryoshi:~/dupe/Hackbot$ ls agents/idor/
idor.md
padi@pad1ryoshi:~/dupe/Hackbot$
```

Design do Hackbot

É necessário entender o melhor design para o problema que queremos resolver. Alguns exemplos de design:

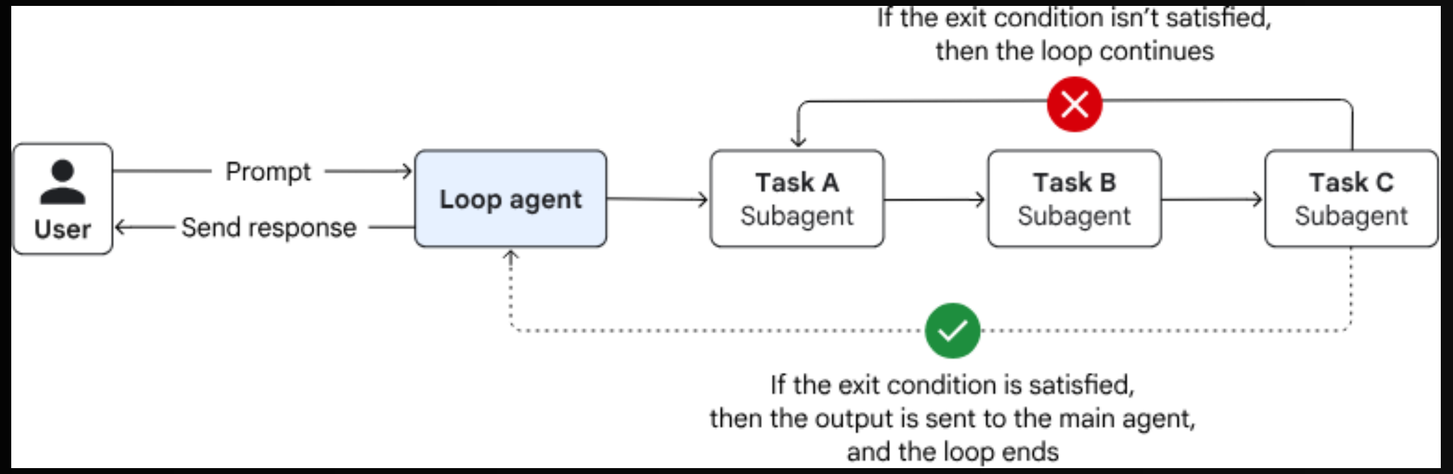
1. Single Agent
2. Sequential Agents
3. Parallel Agents
4. Loop & Critic
5. Coordinator
6. Agent as Tool

O meu hackbot, por exemplo, utiliza mais de um desses designs juntos. (Coordinator + Loop & Critic)

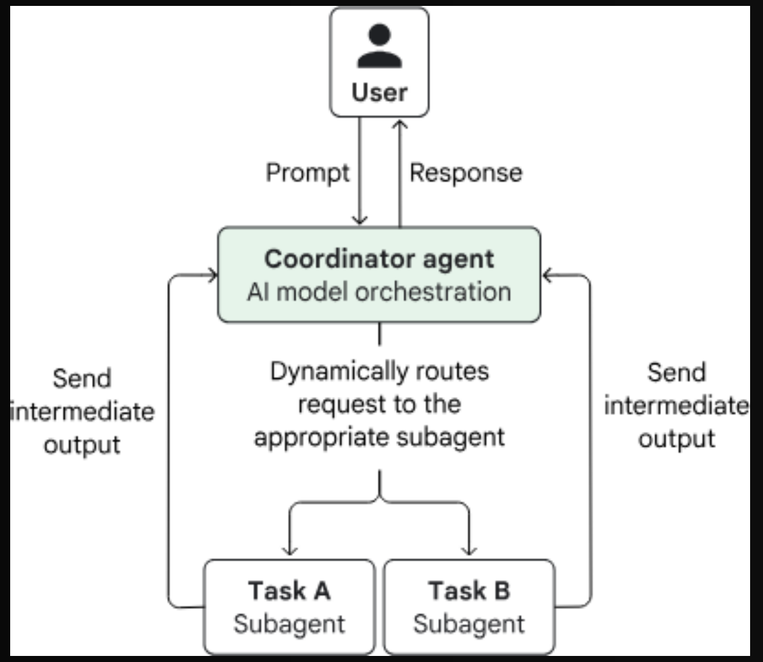




Design do (meu) Hackbot



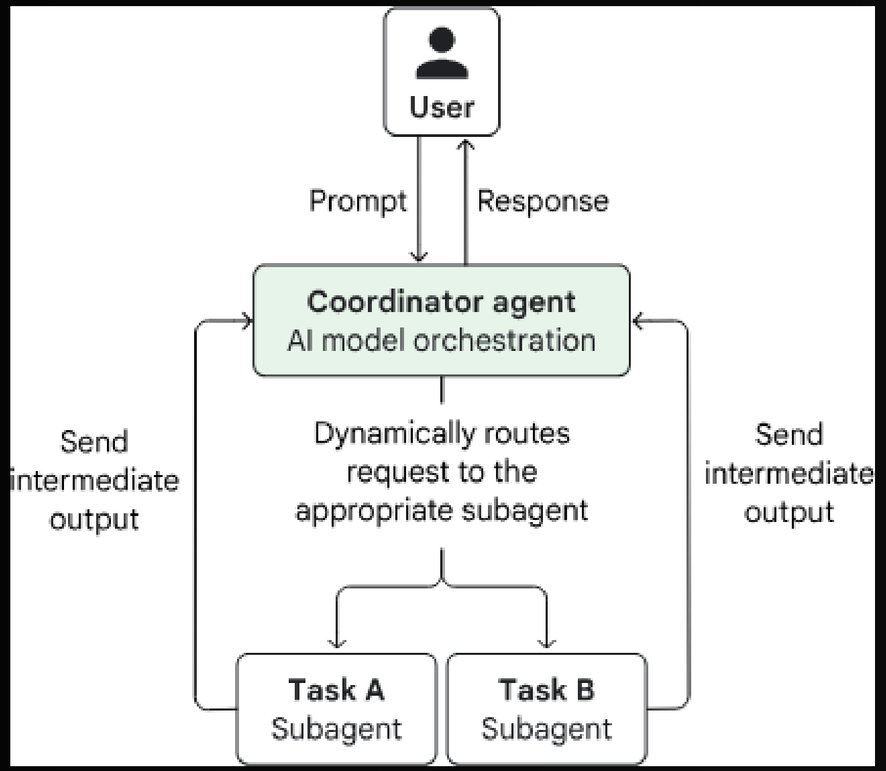
Loop & Critic: O *padrão de agente de loop multiagente* executa repetidamente uma sequência de subagentes especializados até que uma condição de término específica seja atendida.



Coordinator: Agente central, utilizado para direcionar um fluxo de trabalho entre diferentes subagents

https://docs.cloud.google.com/architecture/choose-design-pattern-agentic-ai-system?hl=pt-br

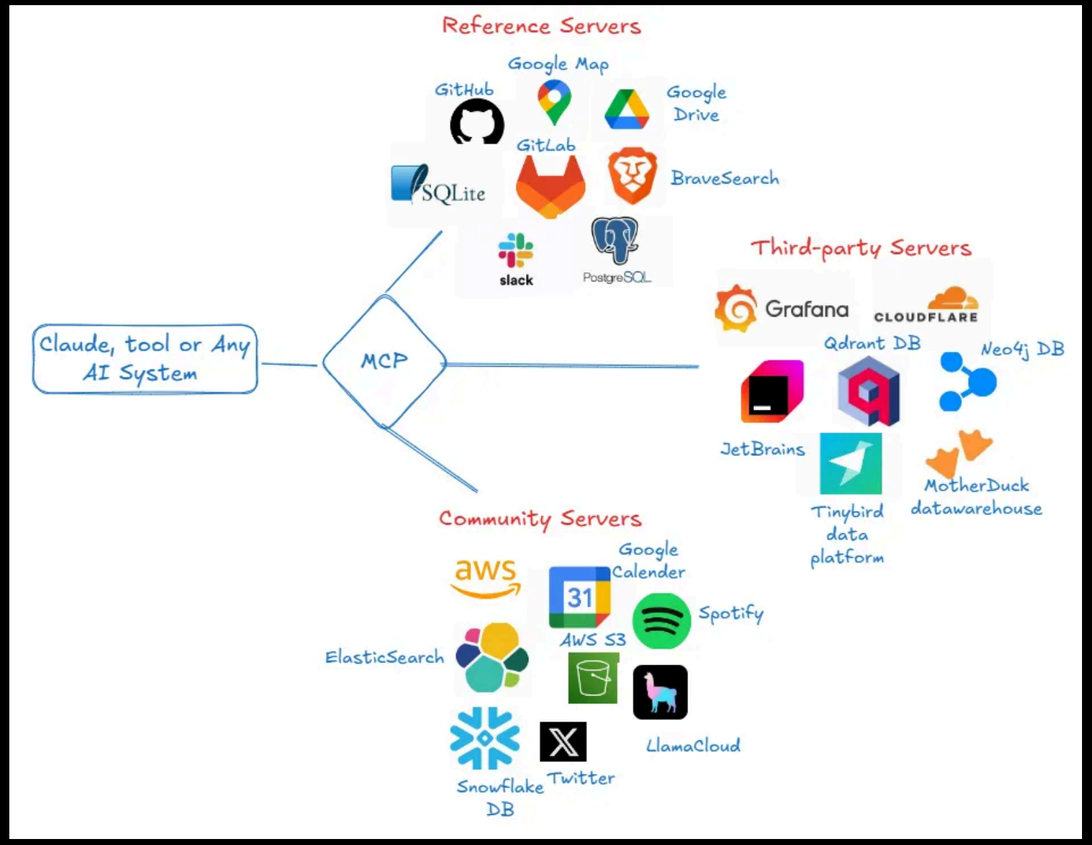
Design do (IFTECH 2026) Hackbot



https://docs.cloud.google.com/architecture/choose-design-pattern-agentic-ai-system?hl=pt-br

Arquitetura MCP

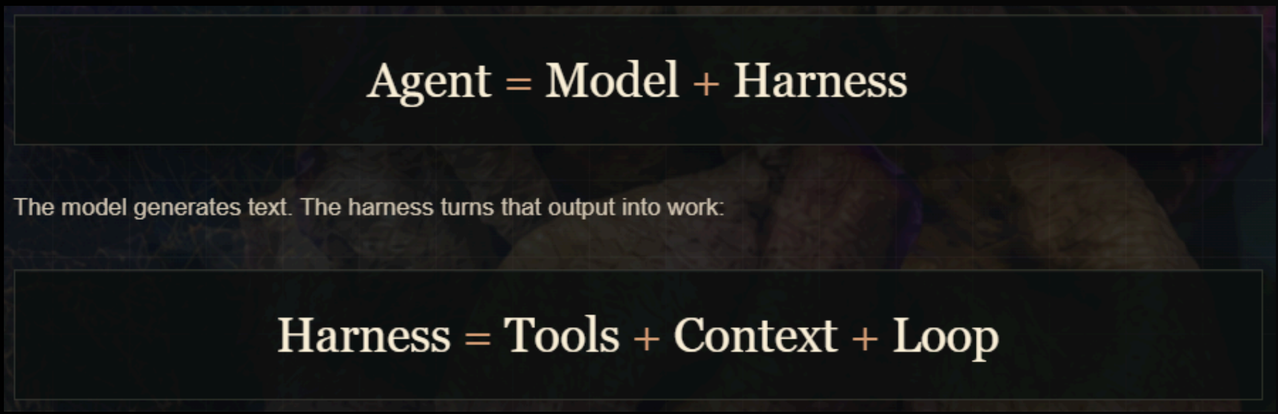
MCP (Model Context Protocol), é basicamente a "API" da sua LLM. Com o protocolo MCP conseguimos sair de apenas um "chat de texto" e conseguimos utilizar ferramentas externas com o nosso modelo. Fazendo com que nossas aplicações de IA consigam se tornar mais completas e robustas.



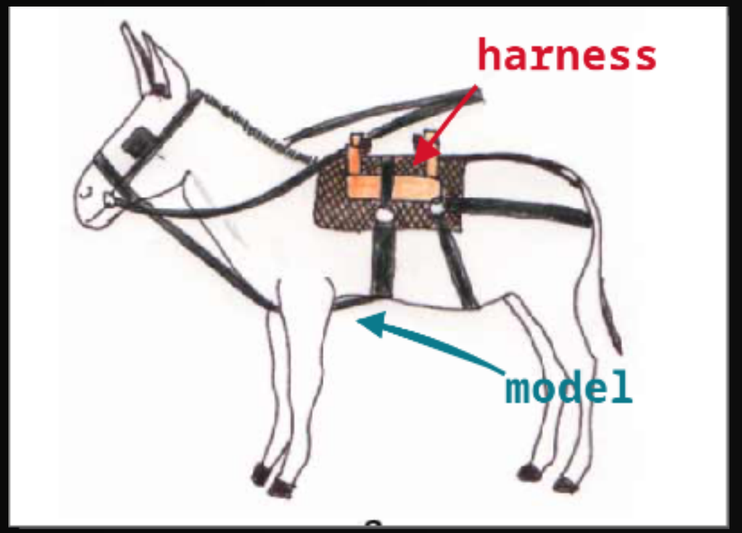
https://www.devshorts.in/p/how-to-build-your-own-mcp-server

Harness

O harness se trata do código que envolve o modelo. É um dos principais componentes! Quanto melhor o harness melhor a capacidade do seu hackbot de se adaptar caso precise trocar de modelo (DeepSeek-pro, Opus-4.6, GPT Sol, KIMI, GLM e etc...).



https://ai-agent-harness.com/



https://github.com/caioluders/talks/blob/main/VibeHacking%20%E2%80%94%20DunaSec%202026.pdf

SKILLS + Humano & IA

SKILLS são basicamente arquivos .md que realizam ações de forma objetiva. Quanto melhor o seu conjunto de SKILLS = melhor seu hacking em larga escala.

"Se você tiver X, faça Y e Z"

```
agents/
├──── recon/
│     ├──── js-discovery.md
│     └──── endpoint-discovery.md
│
├──── vulnerabilities/
│     ├──── idor.md
│     └──── cmdi.md
│
└──── reporting/
      └──── vulnerability-report.md
```

```
padi@pad1ryoshi:~/dupe/Hackbot$ cat agents/idor/idor.md
# IDOR

SKILL is responsible for testing for IDOR vulnerabilities in web applications.

## Trigger

If an endpoint accesses an object using a client-controlled identifier:

1. Identify the object identifier.
2. Identify the object's owner or authorization context.
3. Attempt to access the same object from a different user/context.
4. Compare the responses.

---

## Object Identifiers

If you find parameters such as:

- `id`
- `userId`
- `accountId`
```

SKILLS + Humano & IA

Hackbot = Amplititude

/hackbot-auto:

- O hackbot consegue abordar áreas em larga escala que humanamente é impossível;
- Consome MUITO token mas não se cansa;
- Ótimo para alvos de larga escala... wildcards, codebase gigantesca e etc.

Humano = Profundidade

/hackbot-coop:

- Humano controla as decisões, hackbot testa as hipóteses juntamente com o humano;
- Perfeito para hipóteses ousadas ou ideias “malucas”;
- Gasta seu tempo, melhora a qualidade (depende da skill do humano)

OBS: O seu hackbot não vai ter a sua criatividade (ou vai?), ele vai apenas economizar seu tempo - gastar seu dinheiro... (tokens) - e fazer o trabalho tedioso.

E finalmente...



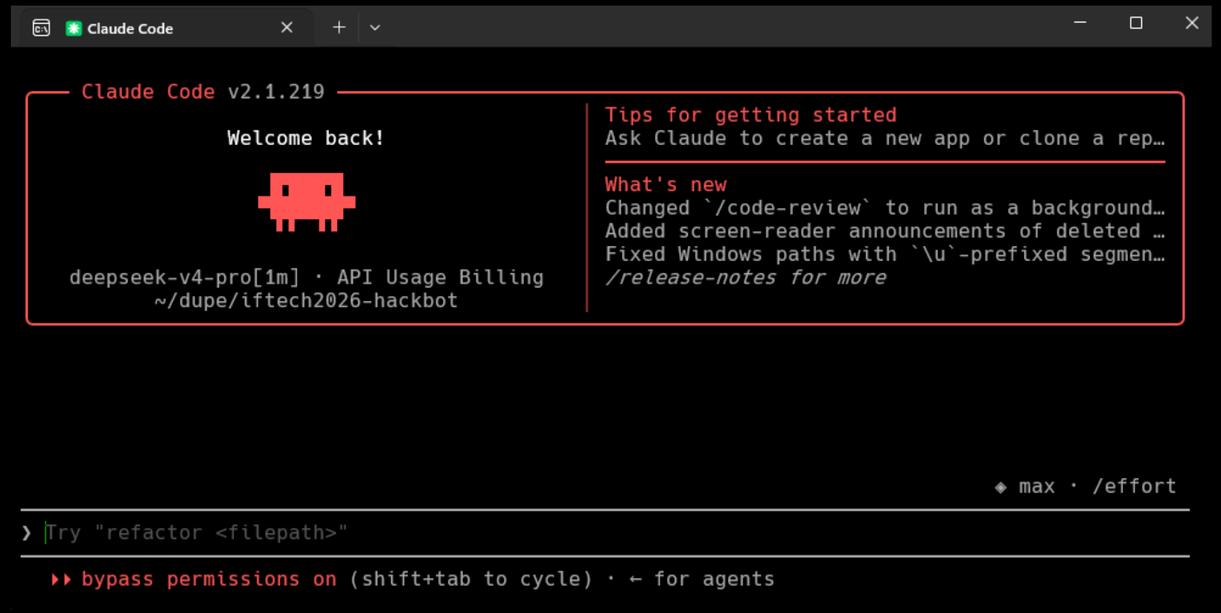
https://mairperkins.co.uk/illustrations/hackbot-for-nottinghams-hack24

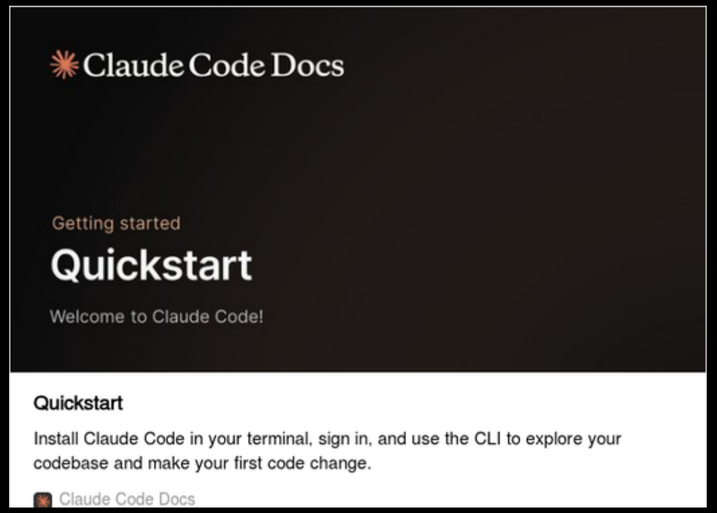
Criando o hackbot + Prompts + Hackbot em prática

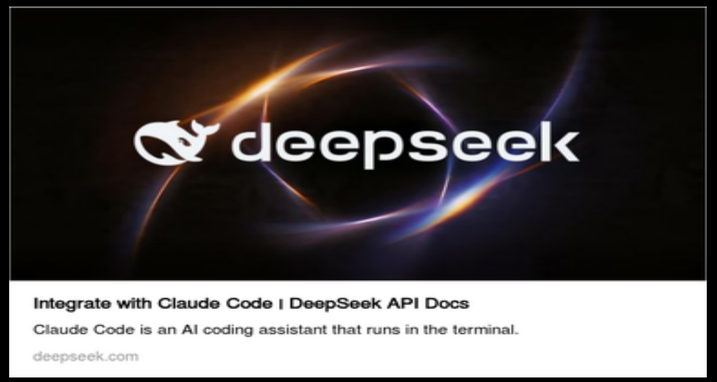
Passo a passo simples:

- Elaborar a ideia, é super importante você saber de fato o que está fazendo. Se você não sabe então por qual motivo o modelo saberia?
  - Eu quero que o meu hackbot tenha X qtds de agentes;
  - Eu quero que o meu agent faça X;
  - Escreva esses processos e fique refinando eles, tudo se inicia a partir de uma ideia.
- Escolha o(s) design(s) do seu hackbot, escolha o design que será utilizado para fazer com que a sua ideia crie “vida”.
- Peça para o próprio modelo melhorar o seu prompt
  - O seu harness precisa ser organizado, ninguém faz algo bem feito com desorganização

Claude-CLI + Deepseek-pro



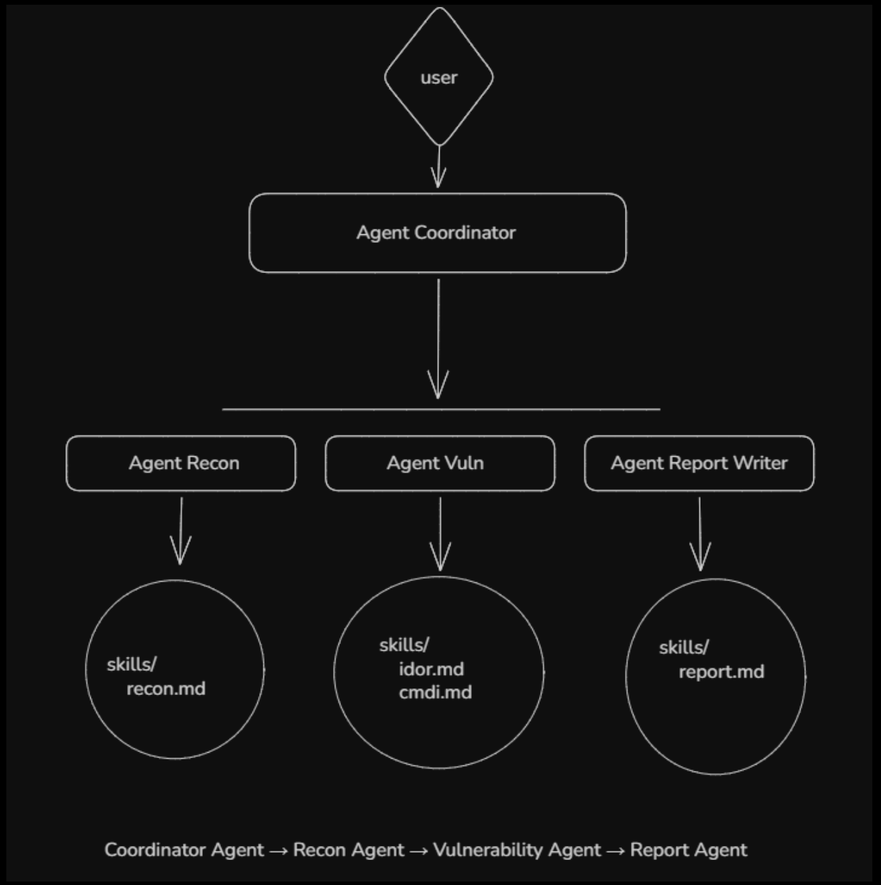




Desing do Hackbot IFTECH-2026

- Elaborar a ideia -> Criar um hackbot baseado em múltiplos agentes capaz de analisar uma aplicação web, realizar reconhecimento, investigar vulnerabilidades e gerar um relatório técnico.
- Escolha o(s) design(s) do seu hackbot → Coordinator + 3 Agents
- Peça para o próprio modelo melhorar o seu prompt → DeepSeek (webchat)

- Modos de operação:
  - /hackbot-auto: Hackbot hackeia de forma autônoma.
  - /hackbot-coop: Humano guia o hackbot.



Prompt para criar o hackbot



OBS: A ideia desse hackbot é simples, ou seja, se você for criar algo mais elaborado = crie de uma forma mais elaborada. Não recomendo utilizar apenas um único prompt para realizar tudo... Pense na ideia, refine a sua ideia, implemente a sua ideia e continue melhorando ela...

Link para o prompt: https://github.com/pad1ryoshi/hackbot-iftech/blob/main/prompts/prompt-inicial.md

```
padi@pad1ryoshi:~/iftech2026-hackbot$ tree .
.
├── CLAUDE.md
├── COORDINATOR.md
├── README.md
├── agents
│   ├── recon
│   │   ├── AGENT.md
│   │   └── skills
│   │       └── recon.md
│   ├── reporter
│   │   └── AGENT.md
│   └── vuln-hunter
│       ├── AGENT.md
│       └── skills
│           ├── cmdi
│           │   └── cmdi.md
│           └── idor
│               └── idor.md
├── modes
│   ├── hackbot-auto.md
│   └── hackbot-coop.md
├── schemas
│   ├── finding.schema.json
│   ├── recon-output.schema.json
│   └── state.schema.json
├── targets
│   └── _template
│       ├── evidence
│       ├── findings
│       ├── recon
│       ├── reports
│       ├── scope.md
│       └── state
│           └── state.json
└── tools
    ├── init-target.sh
    ├── update-state.sh
    └── validate.sh

19 directories, 19 files
```

Vídeo do hackbot em prática.

Vamos testar o nosso hackbot no laboratório de IDOR que fizemos de forma manual 😈😈😈



Vídeo do hackbot em prática.

Realizando code-review no laboratório vulnerável a command injection 😈😈😈



Palavras finais

O mundo de tecnologia evolui constantemente... a melhor solução hoje não necessariamente vai ser a melhor solução amanhã, o melhor LLM hoje não necessariamente vai ser o melhor amanhã...

Se mantenham atualizados, foquem em criar um bom harness que resolva o seu problema e nunca deixem de tentar melhorar.

Dúvidas ?